

MK FRAUD READINESS

Comprehensive fraud-readiness review

Strategic fraud-risk analysis and target-state control blueprint.

ORGANISATION

Kestrel Industrial Supply (Pty) Ltd

NAMED REVIEWER

Named review lead · Review lead

REVIEW DATE

11 August 2026

Confidential · decision support, not a legal opinion or certification

The review scope is bounded by recorded information

This product uses the recorded analytical universe and management review record to interpret exposure, design the target control environment and sequence the 12-month response.

INCLUDED

Deterministic score and maturity; material findings; register; control actions; evidence requirements; scenarios; contradictions; roadmap; review observations; management decisions.

NOT INCLUDED

A re-score, legal opinion, investigation, independent operating-effectiveness validation, certification programme, or conclusion beyond the information supplied.

READING RULE

The recorded assessment answer is never overwritten by narrative. Review notes remain bounded to the named record, population and period; they do not establish independent assurance.

The target state turns diagnosis into management action

The recorded assessment provides the baseline for the target-state design. Review notes are bounded to the supplied records; 63 evidence item(s) remain open and should be closed before management relies on operating effectiveness.

Deterministic readiness	Review notes in scope	Open information items	Decisions required
55	1	63	1
/ 100 · Developing	of 64 records	items requiring action	management / board items

BOARD IMPLICATION

Action accepted by management and scheduled: define and implement red-flag monitoring for vendor master data changes, depot stock adjustments and payroll master changes, with a first coverage report to the Audit and Risk Committee.

The recorded position remains separate from the target state

OVERALL SCORE

55 / 100

COVERAGE

100%

CALCULATED MATURITY

Developing

NOT APPLICABLE RATE

3%

FINAL MATURITY

Developing

CRITICAL / MAJOR GAPS

8 / 0

EXPOSURE POSITION

Not scored

MATURITY CONSTRAINT

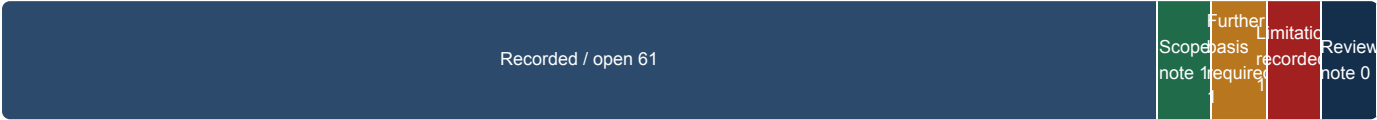
No cap recorded

INTERPRETATION BOUNDARY

These metrics are deterministic outputs from the locked assessment run. They are not changed by review notes; the target-state design and implementation response are presented separately.

Strategic themes and exposure

The deterministic position identifies the themes that need management attention. The exhibit below keeps the score, exposure and target-state response in one traceable view.



3 of 64 items carry a review note; 63 remain open under the locked reconciliation rule.

Source: Kestrel assessment, persisted reviewer record and reconciled evidence register.

Alert definitions for takeover indicators

Digital and Identity Fraud

Evidence not supplied

Approval and business justification

Digital and Identity Fraud

Evidence not supplied

Approved fraud- RACI

Fraud Leadership and Governance

Evidence not supplied

Approved treatment plan with owners and due dates

Fraud Identification

Evidence not supplied

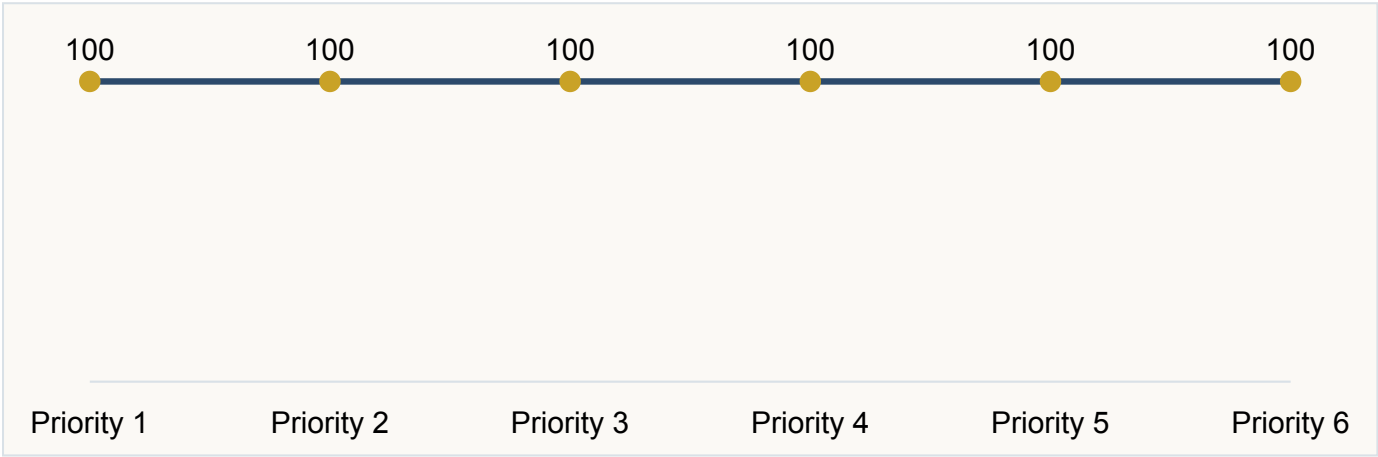
Audit-committee minutes showing independent reporting

Fraud Leadership and Governance

Evidence not supplied

The target operating model connects owners, forums and escalation

The deterministic readiness position remains locked. The Comprehensive value is the operating model that converts the position into accountability, monitoring, investigation, assurance and escalation.



Source: Kestrel assessment, persisted reviewer record and reconciled evidence register.

Management rhythm is the bridge from diagnosis to operation

BOARD / AUDIT COMMITTEE

Review material fraud exposure, unresolved information items, accepted residual and overdue decisions at each formal checkpoint.

EXECUTIVE ACCOUNTABILITY

The accountable executive owns the target control outcome, funding and cross-functional dependencies.

MANAGEMENT FORUM

A monthly fraud- forum reviews exceptions, action ageing, detection signals and control-operation proof.

MONITORING AND DETECTION

Control owners maintain complete populations, exception thresholds, alert ageing and recurring management information.

INCIDENT AND INVESTIGATION

Escalate credible indicators through the agreed incident route, preserve records and assign investigation ownership.

INDEPENDENT ASSURANCE

Treat independent assurance as a separately scoped route; this product does not claim that operating effectiveness has been independently checked.

ESCALATION AND CADENCE

Escalate overdue critical actions, incomplete populations and repeated control exceptions to the accountable executive and oversight forum.

TRACEABILITY

Detailed owners, dependencies, measures and source references remain in the annotated register.

Priority findings require evidence-backed action

The report shows the highest-materiality decision items and keeps review notes distinct from the recorded assessment. The full finding universe remains in the annotated register.

FINDING 1

Recorded self-assessment

Fraud Leadership and Governance: Management owns fraud, while internal audit or assurance functions provide independent review where they exist.

RECORDED RESPONSE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.

FINDING 2

Recorded self-assessment

Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

RECORDED RESPONSE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.

FINDING 3

Recorded self-assessment

Digital and Identity Fraud Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed.

RECORDED RESPONSE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.

Fraud Detection Capability: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

RECORDED RESPONSE

Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.

REVIEWER INTERPRETATION

partially demonstrated in the supplied record, and materially weaker than the self-assessed position. Kestrel asserts transaction and operational monitoring for unusual patterns. The evidence establishes that incidents are captured, investigated and closed, but does not establish that monitoring runs on a defined cycle over a defined population, and the policy contains no red-flag indicator definitions. The organisation is detecting fraud largely through people and after the fact, not through designed surveillance. Reviewed the 2026 incident register (six incidents, four sites) and KIS-POL-FRM-004 v3.1. Two of six incidents originated from data analytics or Internal Audit, which shows genuine proactive capability exists in pockets and should not be understated. However no monitoring output, population reconciliation, coverage report or indicator definition was produced for any period. Limitation: this conclusion rests on documentation only; no system walkthrough, ERP configuration review or re-performance over a transaction population was carried out. Adjusted interpretation: the self-assessed maturity for overstates operating reality and should be read down one level pending indicator definitions and a first coverage report. Owner: Financial Controller. Due date: 30 November 2026. Management response: management accepts the gap and has linked it to the Q4 2026 ERP role remediation already scheduled for the Germiston segregation issue.

Open information gaps limit reliance

RELIANCE LIMITATION

7 item(s) remain recorded or require further basis. These are information gaps that limit reliance, not conclusions about misconduct. The highest-priority four are shown here; the full set remains in the annotated register.

HIGH PRIORITY

Evidence not supplied

Alert definitions for takeover indicators

WHAT MK WANTS TO INSPECT

Whether The organisation can detect or investigate identity misuse, account takeover, impersonation or unauthorised profile changes where relevant operates to the exact expected control standard across the complete in-scope population.

ACCEPTABLE EXAMPLES

Covers authentication, profile change and transaction events together; Retention supports investigation within the defined window; Runbook includes containment actions

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

REVIEW NOTE

Reviewer status recorded; see reviewer observation and limitations.

HIGH PRIORITY

Evidence not supplied

Approval and business justification

WHAT MK WANTS TO INSPECT

Whether Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed operates to the exact expected control standard across the complete in-scope population.

ACCEPTABLE EXAMPLES

Covers human, service, shared and emergency accounts; Separates reviewer from account administrator; Shows owner,, date and closure

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

REVIEW NOTE

Reviewer status recorded; see reviewer observation and limitations.

HIGH PRIORITY

Evidence not supplied

Approved fraud- RACI

WHAT MK WANTS TO INSPECT

Whether Management owns fraud, while internal audit or assurance functions provide independent review where they exist operates to the exact expected control standard across the complete in-scope population.

ACCEPTABLE EXAMPLES

Separates operation from testing for each key control; Gives assurance unrestricted reporting access; Records conflicts and recusals

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

REVIEW NOTE

Reviewer status recorded; see reviewer observation and limitations.

HIGH PRIORITY

Evidence not supplied

Approved treatment plan with owners and due dates

WHAT MK WANTS TO INSPECT

Whether The organisation has completed a structured fraud assessment within the past two years operates to the exact expected control standard across the complete in-scope population.

ACCEPTABLE EXAMPLES

Completed within the last 24 months; Covers the material process population rather than a sample of convenience; Every unacceptable residual has a named owner and due date

WHY IT MATTERS

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

REVIEW NOTE

Reviewer status recorded; see reviewer observation and limitations.

Risk pathways show where exposure may persist

Risk rating remains deterministic. The reviewer assurance layer is shown beside it and does not recalculate priority, likelihood or impact.

RISK PATHWAY	DETERMINISTIC POSITION	REVIEWER INTERPRETATION	TARGET
Unauthorised system access enables transaction or record manipulation Because privileged, administrator or sensitive-data access is not completely restricted, logged and independently recertified, there is a that a privileged user or compromised administrator identity alters records, controls or logs without timely detection. Consequence pathway: confidence in digital controls is damaged; critical systems and audit trails lose integrity; high-impact transactions or data can be manipulated; security and personal-data obligations may be breached.	Critical · Moderate / Severe Self-assessment only, not independently verified	Confidence:	60 days
Fraud Detection Capability control effectiveness Because the assessed control design or operation does not meet the exact expected standard, there is a that without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.	Critical · Moderate / Severe Self-assessment only, not independently verified	rating retained at the analytical level rather than reduced. Detection control effectiveness cannot be evidenced, so residual exposure to undetected internal fraud in procurement, stock and payroll remains materially open. Confidence in this rating is moderate: the direction is well demonstrated in the supplied record, the magnitude is not independently measured. Confidence: MEDIUM	90 days
Continuous Improvement and Fraud Monitoring control effectiveness Because the assessed control design or operation does not meet the exact expected standard, there is a that controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier. Consequence pathway: Impact requires case-specific validation; Operating impact requires case-specific validation.	Critical · Moderate / Severe Self-assessment only, not independently verified	Confidence:	90 days

Plausible pathways show how controls may be bypassed

These are plausible scenarios linked to the recorded analytical universe. They are not allegations and do not evidence that an event occurred.

Without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded

CONFIRMED OPERATING CONTEXT

Fraud Detection Capability: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed, not independently verified.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

EARLY WARNING INDICATORS

A material process unmonitored, or a monitoring cycle missed without escalation.; An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.

LONG-TERM RESPONSE

The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.

DISCLAIMER

ENTRY POINT

The recorded control condition is engaged through Fraud Detection Capability: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

CONTROL BYPASSED

Defined monitoring covers the material transaction and activity population, uses risk-based indicators, and produces reviewable output on a set rhythm rather than relying on incidental discovery.

CONSEQUENCE

Direct -- unreviewed exceptions can allow losses to compound.; Alert backlogs can conceal important anomalies.; Alert backlogs can conceal important anomalies.; Direct -- unreviewed exceptions can allow losses to compound.

IMMEDIATE CONTAINMENT

Escalate to CFO / COO, preserve relevant records and apply the control's escalation threshold: A material process unmonitored, or a monitoring cycle missed without escalation.

TRACEABILITY

Detailed references are retained in the annotated register.

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not an allegation that the event has occurred.

Controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier

CONFIRMED OPERATING CONTEXT

Continuous Improvement and Fraud Monitoring: Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed, not independently verified.

MECHANISM

Misuse can occur when an actor exploits the recorded control condition and controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier.

CONCEALMENT

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it.

EARLY WARNING INDICATORS

An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population.; Review overdue, or a key control found lapsed with no remediation owner.

LONG-TERM RESPONSE

The Head of must run a scheduled review that revisits the fraud assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated and control position to the governing body with owned remediation actions and due dates.

DISCLAIMER

This is a plausible scenario derived from the organisation's self-assessment evidence. It is not

ENTRY POINT

The recorded control condition is engaged through Continuous Improvement and Fraud Monitoring: The organisation periodically reviews its fraud risks and control environment.

CONTROL BYPASSED

A scheduled review reassesses fraud risks, tests whether key controls still operate as designed, and reports a consolidated position with owned actions to governance.

CONSEQUENCE

Impact requires case-specific validation.; Operating impact requires case-specific validation.; Impact requires case-specific validation.; Operating impact requires case-specific validation.

IMMEDIATE CONTAINMENT

Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation threshold: Review overdue, or a key control found lapsed with no remediation owner.

TRACEABILITY

Detailed references are retained in the annotated register.

an allegation that the event has occurred.

Control design must show how operation will be evidenced

The report shows five target control blueprints; the complete deterministic design remains in the annotated register. Review critique is shown beside, and does not mutate, the design.

CONTROL OBJECTIVE	RECORDED STATE	HUMAN DESIGN CRITIQUE	TARGET / OWNER
Close the material control weakness recorded for "Management owns fraud, while internal audit or assurance functions provide independent review where they exist".	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified. The CEO and audit-committee chair must approve a RACI that assigns control operation to management and owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.		Management designs and operates fraud controls; internal audit or another independent function periodically tests them and reports without assuming management responsibility. CEO / Managing Director · 30 days
Close the material control weakness recorded for "Evidence linked to suspected fraud is identified, preserved and handled appropriately".	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified. The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.		Evidence is collected under legal direction where needed, hashed or sealed, logged through every transfer, access-restricted and retained under an approved schedule. General Counsel / COO · 60 days
Close the material control weakness recorded for "Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed".	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified. IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.		Every privileged account is named, justified, least-privileged, strongly authenticated, logged and independently recertified quarterly; emergency access expires automatically. Chief Technology Officer · 60 days
Close the material control weakness recorded for "The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags".	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified. The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.	Design assessment: inadequate as designed. The control as described relies on manual observation and incident reporting; there is no documented indicator set, no defined monitoring population and no coverage measure, so it cannot be operated consistently or tested for effectiveness.	Defined monitoring covers the material transaction and activity population, uses risk-based indicators, and produces reviewable output on a set rhythm rather than relying on incidental discovery. CFO / COO · 90 days
Close the material control weakness recorded for "The organisation periodically reviews its	Partially designed — Some elements exist, but implementation is incomplete, inconsistent or not evidenced.; self-assessed and not independently verified. The Head of must run a scheduled review that		A scheduled review reassesses fraud risks, tests whether key controls still operate as designed, and reports a

CONTROL OBJECTIVE	RECORDED STATE	HUMAN DESIGN CRITIQUE	TARGET / OWNER
fraud risks and control environment".	revisits the fraud assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated and control position to the governing body with owned remediation actions and due dates.		consolidated position with owned actions to governance. CEO / Managing Director · 90 days

Leadership must choose owners and trade-offs

The Comprehensive product moves from diagnosis to decisions with traceable ownership. Each priority choice carries three options, cost/effort, benefit, trade-off and the MK recommendation.

ACCOUNTABLE EXECUTIVE MANDATE

Decision required

Approve accountable executive mandates and escalation authority for priority remediation.

WHY NOW

Hard-gate, governance and maturity-limiting controls require authority to allocate resources and resolve blockers.

OPTIONS, COST, BENEFIT AND TRADE-OFF

Option A — Option A - retain accountability with the Finance Director (rejected: design and adjudication would sit with one executive); cost/effort: Cost and effort require management confirmation before approval.; benefit: Builds durable ownership inside the organisation.; trade-off: Uses internal capacity and may move more slowly where capability is immature.; rejection reason: rejected: design and adjudication would sit with one executive | Option B — Option B - delegate detection design to the Financial Controller with quarterly Audit and Committee reporting (recommended and accepted); cost/effort: Cost and effort require management confirmation before approval.; benefit: Adds focused specialist capacity against the named priority.; trade-off: Introduces external cost, handover effort and a dependency on clear scope.; recommended option | Option C — Option C - outsource monitoring to an external provider (rejected at current maturity: Kestrel cannot yet specify the indicator set it needs); cost/effort: Cost and effort require management confirmation before approval.; benefit: Combines internal accountability with targeted specialist support.; trade-off: Needs explicit boundaries so ownership and escalation are not diluted.; rejection reason: rejected at current maturity: Kestrel cannot yet specify the indicator set it needs

MK RECOMMENDATION

Viable options considered. Option A - leave accountability with the Finance Director as the policy currently states. Trade-off: preserves the approved policy and needs no change control, but the Finance Director is already the escalation route for reported incidents, so the same executive would own both detection design and incident adjudication, which weakens independence. Option B - delegate detection design to the Financial Controller with quarterly Committee reporting. Trade-off: separates design from adjudication and uses an existing budgeted workstream; requires a minor policy amendment at the next review. Option C - outsource monitoring to an external provider. Trade-off: fastest route to coverage, but at this maturity Kestrel cannot yet specify what it wants monitored, so the provider would define the indicators and the organisation would not own them. Management Option B accepted by the Finance Director on review. Owner:

RECOMMENDATION RATIONALE

The recommendation follows the linked deterministic and priorities; management must confirm the final route, cost and delivery capacity.

Financial Controller. Date: 30 November 2026 for the first quarterly report to the Committee.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

TARGET DATE

30 days

MANAGEMENT DECISION RECORD

Management to confirm the selected option, accountable owner and date.

CONSEQUENCE OF DELAY

Priority controls remain ownerless or blocked and the maturity reading remains constrained.

RISK TREATMENT DECISION

Decision required

Choose and record remediation rather than passive acceptance for Critical and High risks.

WHY NOW

Plausible consequence pathways require an explicit leadership treatment.

OPTIONS, COST, BENEFIT AND TRADE-OFF

Option A — Option A — deliver through existing internal ownership; cost/effort: Cost and effort require management confirmation before approval.; benefit: Builds durable ownership inside the organisation.; trade-off: Uses internal capacity and may move more slowly where capability is immature.; rejection reason: Not preferred where the target period cannot be met with internal capacity. | Option B — Option B — use bounded specialist support; cost/effort: Cost and effort require management confirmation before approval.; benefit: Adds focused specialist capacity against the named priority.; trade-off: Introduces external cost, handover effort and a dependency on clear scope.; recommended option | Option C — Option C — combine internal ownership with targeted specialist support; cost/effort: Cost and effort require management confirmation before approval.; benefit: Combines internal accountability with targeted specialist support.; trade-off: Needs explicit boundaries so ownership and escalation are not diluted.; rejection reason: Not preferred where the organisation cannot fund or coordinate both routes.

MK RECOMMENDATION

Deterministic recommendation: Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.

RECOMMENDATION RATIONALE

The recommendation follows the linked deterministic and priorities; management must confirm the final route, cost and delivery capacity.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

TARGET DATE

30 days

MANAGEMENT DECISION RECORD

Management to confirm the selected option, accountable owner and date.

CONSEQUENCE OF DELAY

Known pathways remain untreated without a documented acceptance basis.

CONTROL DESIGN STANDARD

Decision required

Approve exact question-level control designs as the minimum implementation standard.

WHY NOW

Functions need one design baseline rather than independent interpretations of the findings.

OPTIONS, COST, BENEFIT AND TRADE-OFF

Option A — Option A — deliver through existing internal ownership; cost/effort: Cost and effort require management confirmation before approval.; benefit: Builds durable ownership inside the organisation.; trade-off: Uses internal capacity and may move more slowly where capability is immature.; rejection reason: Not preferred where the target period cannot be met with internal capacity. | Option B —

Option B — use bounded specialist support; cost/effort: Cost and effort require management confirmation before approval.; benefit: Adds focused specialist capacity against the named priority.; trade-off: Introduces external cost, handover effort and a dependency on clear scope.; recommended option | Option C — Option C — combine internal ownership with targeted specialist support; cost/effort: Cost and effort require management confirmation before approval.; benefit: Combines internal accountability with targeted specialist support.; trade-off: Needs explicit boundaries so ownership and escalation are not diluted.; rejection reason: Not preferred where the organisation cannot fund or coordinate both routes.

MK RECOMMENDATION

Deterministic recommendation: Adopt the control-improvement register; deviations require documented oversight approval.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

MANAGEMENT DECISION RECORD

Management to confirm the selected option, accountable owner and date.

RECOMMENDATION RATIONALE

The recommendation follows the linked deterministic and priorities; management must confirm the final route, cost and delivery capacity.

TARGET DATE

30 days

CONSEQUENCE OF DELAY

Partial or inconsistent designs fail to address the causal pathway.

FUNDING AND RESOURCE ALLOCATION

Decision required

Approve specialist capacity and resources for high-difficulty controls.

WHY NOW

High-difficulty controls cannot meet target periods without committed capacity.

MK RECOMMENDATION

Deterministic recommendation: Fund the named supporting functions and require a resource-confirmed delivery plan.

ACCOUNTABLE EXECUTIVE

General Counsel / COO

MANAGEMENT DECISION RECORD

Management to confirm the selected option, accountable owner and date.

OPTIONS, COST, BENEFIT AND TRADE-OFF

Option A — Option A — deliver through existing internal ownership; cost/effort: Cost and effort require management confirmation before approval.; benefit: Builds durable ownership inside the organisation.; trade-off: Uses internal capacity and may move more slowly where capability is immature.; rejection reason: Not preferred where the target period cannot be met with internal capacity. | Option B — Option B — use bounded specialist support; cost/effort: Cost and effort require management confirmation before approval.; benefit: Adds focused specialist capacity against the named priority.; trade-off: Introduces external cost, handover effort and a dependency on clear scope.; recommended option | Option C — Option C — combine internal ownership with targeted specialist support; cost/effort: Cost and effort require management confirmation before approval.; benefit: Combines internal accountability with targeted specialist support.; trade-off: Needs explicit boundaries so ownership and escalation are not diluted.; rejection reason: Not preferred where the organisation cannot fund or coordinate both routes.

RECOMMENDATION RATIONALE

The recommendation follows the linked deterministic and priorities; management must confirm the final route, cost and delivery capacity.

TARGET DATE

60 days

CONSEQUENCE OF DELAY

The highest-complexity gaps remain open despite nominal approval.

Agreed actions define ownership and proof

DECISION / ACTION	OWNER	TARGET DATE	STATUS	COMPLETION EVIDENCE
Action accepted by management and scheduled: define and implement red-flag monitoring for vendor master data changes, depot stock adjustments and payroll master changes, with a first coverage report to the Audit and Committee. Rationale: the 2026 incident register shows losses clustering in exactly these three processes (stock misappropriation R48,200 (recorded in the supplied incident register) at Germiston, attempted vendor bank detail change at head office, suspected ghost employee R22,400 (recorded in the supplied incident register)), so indicator work targeted at them addresses demonstrated rather than theoretical exposure. Recorded analytical references retained in the register., and. Sequencing note: this action is deliberately bound to the Q4 2026 ERP role remediation already committed for the Germiston segregation exception, so role redesign and monitoring design land together rather than twice.	Financial Controller		Open	Update the annotated register with the agreed evidence and effectiveness measure.

Sequenced action creates a reliable control baseline

Near-term actions preserve the dependency-closed Comprehensive projection of the analytical roadmap. The full L1 roadmap remains in the annotated register.

PERIOD	DELIVERABLE	OWNER	DEPENDENCY / EVIDENCE
30 days	Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.	CEO / Managing Director	No dependency recorded · Approved fraud- RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate
30 days	Apply immediate escalation at "A qualifying matter escalated late, or an escalation routed only through an implicated manager." and deliver the exact control design: The Head of must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud- executive or audit-committee chair where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Head of	No dependency recorded · Evidence of alternate route bypassing implicated management; Quarterly escalation timeliness review; Training completion records; Written escalation criteria and routes
30 days	Apply immediate escalation at "Any site or worker group below the awareness threshold, or reporting material not reaching non-desk staff." and deliver the exact control design: The ethics owner must publish reporting routes in plain language across the channels the workforce actually uses — induction packs, payslip inserts, notice boards at depots and sites, intranet and supervisor briefings — covering line manager, confidential channel and conflict-free alternate route; awareness is tested periodically by short survey or spot check, and results below threshold trigger a targeted re-communication for the affected sites or teams.	Chief People Officer / COO	No dependency recorded · Awareness test or survey results; Distribution evidence covering non-desk and contract staff; Published reporting route material; Targeted re-communication records where results were low
60 days	Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.	Chief Technology Officer	No dependency recorded · Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets
60 days	Apply immediate escalation at "Activation before verification, an unapproved exception, or a sensitive change without re-verification." and deliver the exact control design: The process owner must define	COO / CFO	No dependency recorded · Defined verification points and required checks;

PERIOD	DELIVERABLE	OWNER	DEPENDENCY / EVIDENCE
	the points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents checked for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.		Exception approvals; re-verification records for sensitive changes; Verification records with source and date
60 days	Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	General Counsel / COO	No dependency recorded · Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction
60 days	Apply immediate escalation at "Any high- alert unassigned after one business day or SLA breach rate above 5%." and deliver the exact control design: The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-alerts immediately and all overdue alerts weekly; performs a monthly closure-quality sample.	CFO / COO	No dependency recorded · Alert investigation log; Disposition evidence; Exception population and control totals; Monthly quality-review sample
60 days	obtain separately scoped assurance for that "The organisation monitors emerging fraud threats affecting its industry, geography or operating environment" holds across the complete population and record whether every minimum evidence characteristic is met.	Head of	No dependency recorded · Control reviews or accept decisions arising; Named source list with assigned responsibility; Relevance assessment against processes and channels; Threat log with dated entries

MONTHS 4–6 — EMBED

Run the first full management-information cycle against the approved control designs and close dependency-held actions.

MONTHS 7–12 — MATURE

Refresh the view, effectiveness measures and escalation rhythm through the agreed management cycle.

IMPLEMENTATION RULE

Do not close an action on narrative completion alone. Record the operating evidence, owner and effectiveness measure in the annotated register.

Uncertainty remains until the information boundary closes

The following matters remain uncertain until their information boundary is closed or management formally accepts the residual risk.

- Alert definitions for takeover indicators · Evidence not supplied · Reviewer status recorded; see reviewer observation and limitations.
- Approval and business justification · Evidence not supplied · Reviewer status recorded; see reviewer observation and limitations.
- Approved fraud- RACI · Evidence not supplied · Reviewer status recorded; see reviewer observation and limitations.
- Approved treatment plan with owners and due dates · Evidence not supplied · Reviewer status recorded; see reviewer observation and limitations.
- Audit-committee minutes showing independent reporting · Evidence not supplied · Reviewer status recorded; see reviewer observation and limitations.
- Chain-of-custody forms · Evidence not supplied · Reviewer status recorded; see reviewer observation and limitations.
- Consolidated report to governance with actions and due dates · Evidence not supplied · Reviewer status recorded; see reviewer observation and limitations.

TRACKING RECOMMENDATION

Board oversight should track the open information count, age of open actions, proof coverage for high-priority controls and overdue management decisions.

The information universe reconciles to one conclusion

The supplied information ledger is reconciled before management conclusions are presented. Every item has one and only one recorded state.

Total information items 64 complete request universe	Review notes in scope 0 review records attached	Stated-scope notes 1 bounded review notes	Open information 63 items requiring action
---	--	--	---

RECONCILIATION CHECK	RESULT	MANAGEMENT READING
Recorded + review note = total	$61 + 0 = 64$	Open items remain bounded as recorded information.
Review-note states reconcile to reviewed items	$1 + 1 + 1 + 0 + 0 = 0$	No review state is silently dropped.
Open-information formula	$63 = \text{recorded} + \text{further basis required} + \text{limitation recorded}$	Closure requires defined proof or a recorded management decision.

RELIANCE BOUNDARY

A supplied record can inform only the stated population, period and control characteristic. It does not convert unrelated or unrecorded items into assurance.

Recorded review observations preserve the human record

These observations are the supplied human review record. The annotated register retains the complete technical traceability.

SUBJECT	RECORDED POSITION	EVIDENCE EXAMINED	LIMITATION / RESPONSE
Management review record	Design weakness: the control has no specification. Without red-flag definitions per process, monitoring frequency, population scope and an exception-handling route, two competent operators would monitor differently and neither could be shown to be wrong. Recommended adjustment: (1) define red-flag indicators for the three highest-value processes first - vendor master data changes, stock adjustments at depots, and payroll master changes, which is where the 2026 incidents actually clustered; (2) fix a monthly monitoring cycle with a named preparer and an named reviewer; (3) produce a coverage report reconciling monitored population to the ERP transaction population; (4) route exceptions into the existing incident register so detection and response become one measured pipeline rather than two.	Recorded source references retained in the annotated register.	No linked recorded.
Management review record	Viable options considered. Option A - leave accountability with the Finance Director as the policy currently states. Trade-off: preserves the approved policy and needs no change control, but the Finance Director is already the escalation route for reported incidents, so the same executive would own both detection design and incident adjudication, which weakens independence. Option B - delegate detection design to the Financial Controller with quarterly Committee reporting. Trade-off: separates design from adjudication and uses an existing budgeted workstream; requires a minor policy amendment at the next review. Option C - outsource monitoring to an external provider. Trade-off: fastest route to coverage, but at this maturity Kestrel cannot yet specify what it wants monitored, so the provider would define the indicators and the organisation would not own them. Management Option B accepted by the Finance Director on review. Owner: Financial Controller. Date: 30 November 2026 for the first quarterly report to the Committee.	Recorded source references retained in the annotated register.	No linked recorded.
Management review record	partially demonstrated in the supplied record, and materially weaker than the self-assessed position. Kestrel asserts transaction and operational monitoring for unusual patterns. The evidence establishes that incidents are captured, investigated and closed, but does not establish that monitoring runs on a defined cycle over a defined population, and the policy contains no red-flag indicator definitions. The organisation is detecting fraud largely through people and after the fact, not through designed surveillance. Reviewed the 2026 incident register (six incidents, four sites) and KIS-POL-FRM-004 v3.1. Two of six incidents originated from data analytics or Internal Audit, which shows genuine proactive capability exists in pockets and should not be understated. However no monitoring output, population reconciliation, coverage report or indicator definition was produced for any period. Limitation: this conclusion rests on documentation only; no system walkthrough, ERP configuration review or re-performance over a transaction population was carried out. Adjusted interpretation: the self-assessed maturity for overstates operating reality and should be read down one level pending indicator definitions and a first coverage report. Owner: Financial Controller. Due date: 30 November 2026. Management response: management accepts the gap and has linked it to the Q4 2026 ERP role remediation already scheduled for the Germiston segregation issue.	Recorded source references retained in the annotated register.	Linked and action retained in the register.

REVIEW DISCIPLINE

A review observation is not a replacement for the deterministic answer. It records the supplied context and where management still needs to close the information boundary.

Effectiveness depends on repeatable proof

Closure is evidenced through population completeness, approval traceability, exception ageing and a repeatable effectiveness measure.

CONTROL PRIORITY	ACCOUNTABLE OWNER	FIRST EVIDENCE DELIVERABLE	EFFECTIVENESS MEASURE
Close the material control weakness recorded for "Management owns fraud, while internal audit or assurance functions provide independent review where they exist".	CEO / Managing Director	Approved fraud- RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate	No key fraud control is both operated and independently certified by the same accountable function.
Close the material control weakness recorded for "Evidence linked to suspected fraud is identified, preserved and handled appropriately".	General Counsel / COO	Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
Close the material control weakness recorded for "Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed".	Chief Technology Officer	Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
Close the material control weakness recorded for "The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags".	CFO / COO	Coverage report against process fraud maps; Monitoring output for recent periods; Population reconciliation to source systems; Red-flag indicator definitions per process	Monitoring covers all material processes on rhythm with reconciled population totals and routed output.
Close the material control weakness recorded for "The organisation periodically reviews its fraud risks and control environment".	CEO / Managing Director	Consolidated report to governance with actions and due dates; Key control operating evidence sampled in the period; Lapsed or degraded control register; Review scope and schedule	Every key control is evidence-tested within the review cycle, with lapses remediated by due date.

CLOSURE RULE

Close only when the register shows the population, exceptions, approvals, operating sample and next effectiveness review.

Options make cost, benefit and trade-offs explicit

Each decision is presented with distinct options so management can record cost, speed, ownership and control consequences explicitly.

Viable options considered. Option A - leave accountability with the Finance Director as the policy currently states. Trade-off: preserves the approved policy and needs no change control, but the Finance Director is already the escalation route for reported incidents, so the same executive would own both detection design and incident adjudication, which weakens independence. Option B - delegate detection design to the Financial Controller with quarterly Committee reporting. Trade-off: separates design from adjudication and uses an existing budgeted workstream; requires a minor policy amendment at the next review. Option C - outsource monitoring to an external provider. Trade-off: fastest route to coverage, but at this maturity Kestrel cannot yet specify what it wants monitored, so the provider would define the indicators and the organisation would not own them. Management decision: Option B accepted by the Finance Director on review. Owner: Financial Controller. Date: 30 November 2026 for the first quarterly report to the Committee.

The recommendation follows the linked deterministic finding and risk priorities; management must confirm the final route, cost and delivery capacity.

Decision owner: CEO / Managing Director · Decision deadline: 30 days

Option	Cost / effort	Benefit / recommendation	Trade-off	Rejection reason / status
Approve accountable executive mandates and escalation authority for priority remediation. · Option A - retain accountability with the Finance Director (rejected: design and adjudication would sit with one executive)	Cost and effort require management confirmation before approval.	Builds durable ownership inside the organisation.	Uses internal capacity and may move more slowly where capability is immature.	rejected: design and adjudication would sit with one executive
Approve accountable executive mandates and escalation authority for priority remediation. · Option B - delegate detection design to the Financial Controller with quarterly Audit and Risk Committee reporting (recommended and accepted)	Cost and effort require management confirmation before approval.	Adds focused specialist capacity against the named priority.	Introduces external cost, handover effort and a dependency on clear scope.	Viable options considered. Option A - leave accountability with the Finance Director as the policy currently states. Trade-off: preserves the approved policy and needs no change control, but the Finance Director is already the escalation route for reported incidents, so the same executive would own both detection design and incident adjudication, which weakens independence. Option B - delegate detection design to the Financial Controller with quarterly Committee reporting. Trade-off: separates design from adjudication and uses an existing budgeted workstream; requires a minor policy amendment at the next review. Option C - outsource monitoring to an external provider. Trade-off: fastest route to coverage, but at this maturity Kestrel cannot yet specify what it wants monitored, so the provider would define the indicators and the organisation would not own them. Management decision: Option B accepted by the Finance Director on review. Owner: Financial Controller. Date: 30

Option	Cost / effort	Benefit / recommendation	Trade-off	Rejection reason / status
				November 2026 for the first quarterly report to the Committee.
Approve accountable executive mandates and escalation authority for priority remediation. · Option C - outsource monitoring to an external provider (rejected at current maturity: Kestrel cannot yet specify the indicator set it needs)	Cost and effort require management confirmation before approval.	Combines internal accountability with targeted specialist support.	Needs explicit boundaries so ownership and escalation are not diluted.	rejected at current maturity: Kestrel cannot yet specify the indicator set it needs
Choose and record remediation rather than passive acceptance for Critical and High risks. · Option A — deliver through existing internal ownership	Cost and effort require management confirmation before approval.	Builds durable ownership inside the organisation.	Uses internal capacity and may move more slowly where capability is immature.	Not preferred where the target period cannot be met with internal capacity.
Choose and record remediation rather than passive acceptance for Critical and High risks. · Option B — use bounded specialist support	Cost and effort require management confirmation before approval.	Adds focused specialist capacity against the named priority.	Introduces external cost, handover effort and a dependency on clear scope.	Deterministic recommendation: Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.
Choose and record remediation rather than passive acceptance for Critical and High risks. · Option C — combine internal ownership with targeted specialist support	Cost and effort require management confirmation before approval.	Combines internal accountability with targeted specialist support.	Needs explicit boundaries so ownership and escalation are not diluted.	Not preferred where the organisation cannot fund or coordinate both routes.
Approve exact question-level control designs as the minimum implementation standard. · Option A — deliver through existing internal ownership	Cost and effort require management confirmation before approval.	Builds durable ownership inside the organisation.	Uses internal capacity and may move more slowly where capability is immature.	Not preferred where the target period cannot be met with internal capacity.
Approve exact question-level control designs as the minimum implementation standard. · Option B — use bounded specialist support	Cost and effort require management confirmation before approval.	Adds focused specialist capacity against the named priority.	Introduces external cost, handover effort and a dependency on clear scope.	Deterministic recommendation: Adopt the control-improvement register; deviations require documented oversight approval.
Approve exact question-level control designs as the minimum implementation standard. · Option C — combine internal ownership with targeted specialist support	Cost and effort require management confirmation before approval.	Combines internal accountability with targeted specialist support.	Needs explicit boundaries so ownership and escalation are not diluted.	Not preferred where the organisation cannot fund or coordinate both routes.

Option	Cost / effort	Benefit / recommendation	Trade-off	Rejection reason / status
Approve specialist capacity and resources for high-difficulty controls. · Option A — deliver through existing internal ownership	Cost and effort require management confirmation before approval.	Builds durable ownership inside the organisation.	Uses internal capacity and may move more slowly where capability is immature.	Not preferred where the target period cannot be met with internal capacity.
Approve specialist capacity and resources for high-difficulty controls. · Option B — use bounded specialist support	Cost and effort require management confirmation before approval.	Adds focused specialist capacity against the named priority.	Introduces external cost, handover effort and a dependency on clear scope.	Deterministic recommendation: Fund the named supporting functions and require a resource-confirmed delivery plan.
Approve specialist capacity and resources for high-difficulty controls. · Option C — combine internal ownership with targeted specialist support	Cost and effort require management confirmation before approval.	Combines internal accountability with targeted specialist support.	Needs explicit boundaries so ownership and escalation are not diluted.	Not preferred where the organisation cannot fund or coordinate both routes.

Source: Kestrel assessment, persisted reviewer record and reconciled evidence register.

Management cadence converts information into oversight

The review becomes useful when owners convert the information boundary into a repeatable management rhythm.

MONTHLY

Review high- detection rules, alert ageing, supplier bank-detail exceptions and privileged-access exceptions.

QUARTERLY

Reconcile the fraud- population, committee challenge, whistleblowing route coverage and awareness exceptions.

BOARD CHECKPOINT

Review recorded position, open information count, action ageing, accepted residual and status.

ESCALATION

Escalate overdue critical exceptions, incomplete populations and any control claim that cannot be reproduced from the named records.

MANAGEMENT READINESS CHECK

Can the accountable owner reproduce the record, explain the exception threshold and show the defined control measure operating again after remediation?

The method and limitations bound the conclusion

ANALYTICAL BASIS

Existing locked deterministic score, maturity, evidence-model material findings, register, control-action register, evidence requirements, scenarios, contradictions and roadmap.

REVIEW BASIS

Named review observations, supplied records, limitations, adjusted interpretation and management responses supplied for this engagement.

LIMITATIONS

No inference beyond the information supplied; no legal or forensic conclusion; no independent operating-effectiveness validation; no silent mutation of answers.

TRACEABILITY

Detailed source, and methodology references are retained in the annotated register.

CONTROL COMPLETENESS

What; Who; Population; Frequency; Evidence retained; Independent check; Escalation trigger / recipient; SLA; Effectiveness measure; Failure response.

Source: persisted assessment, analytical model and management review record.

BASIS STATEMENT

This report is based on recorded responses and supplied review records. It does not independently verify operating effectiveness unless separately scoped to obtain and review that evidence.

The named reviewer records the review boundary

REVIEWER

Named review lead

ROLE

Review lead

REVIEW DATE

11 August 2026

SIGN-OFF STATUS

Signed

SIGNED AT

11 August 2026

REVIEWER NOTE

I have reviewed the submitted evidence, the analytical findings and the reviewer records for Kestrel Industrial Supply (Pty) Ltd, and I sign off artefact version 1 for release. Detection capability is recorded as further basis required on the evidence supplied; the segregation of duties procedure is demonstrated in the supplied record with a disclosed Germiston exception. Scope limitation: documentation review only, no ERP walkthrough or transaction re-performance.

SCOPE ACKNOWLEDGEMENT

This report is a decision-support deliverable. It is bounded by the information supplied, the evidence examined and the limitations recorded by the named reviewer.